



Tóm tắt cơ sở an toàn thông tin E22

Cơ sở an toàn thông tin (Học viện Công nghệ Bưu chính Viễn thông)



Scan to open on Studocu

NỘI DUNG 1: TỔNG QUAN VỀ AN TOÀN BẢO MẬT HỆ THỐNG THÔNG TIN

1. Giới thiệu về ATTT và an toàn hệ thống thông tin

1. Tại sao cần đảm bảo an toàn thông tin và hệ thống thông tin?

- Thế giới kết nối ngày càng sâu rộng.
- Nguy cơ mất an toàn thông tin ngày càng tăng, đe dọa hệ thống, mạng.

2. Thế giới kết nối:

- Mọi thiết bị tính toán và truyền thông đều có kết nối Internet.
- Hệ thống kết nối sâu rộng (smart community, smart city, smart home).
- Xu hướng kết nối mọi vật (IoT, IoE).
- Hệ thống không kết nối khả năng sử dụng hạn chế.

3. Các nguy cơ đe dọa:

- Tấn công từ tin tặc.
- Lạm dụng từ người dùng.
- Lây nhiễm phần mềm độc hại.
- Nguy cơ nghe trộm, đánh cắp và sửa đổi thông tin.
- Lỗi, khiếm khuyết phần cứng, phần mềm.

4. Hệ thống thông tin (IS - Information System) là gì?

- Hệ thống tích hợp thu thập, lưu trữ, xử lý và chuyển giao thông tin, tri thức và sản phẩm số.
- Các tổ chức sử dụng để tương tác với khách hàng, nhà cung cấp, cơ quan chính quyền, quảng bá, cạnh tranh.

5. Hệ thống thông tin hoạt động như thế nào ?

- Gồm có đầu vào (input), đầu ra (output), cơ chế xử lý.
- Môi trường xung quanh của hệ thống (Suppliers, Customers,...)

6. Các loại hệ thống thông tin (mô hình tháp):

- Hệ thống xử lý giao dịch (TPS) - Nhân viên (Workers).
- Hệ thống thông tin quản lý (MIS) - Quản lý bộ phận (Middle Managers).
- Hệ thống trợ giúp quyết định (DSS) - Quản lý cao cấp (Senior Managers).
- Hệ thống thông tin điều hành (EIS) - Giám đốc điều hành (Executives).

7. Một số hệ thống thông tin điển hình:

- Kho dữ liệu, lập kế hoạch nguồn lực doanh nghiệp, hệ thống doanh nghiệp, chuyên gia, máy tìm kiếm, thông tin địa lý, toàn cầu, tự động hóa văn phòng.

8. Hệ thống thông tin dựa trên máy tính (Computer-Based IS):

- Sử dụng công nghệ máy tính để thực thi nhiệm vụ.
- Các thành phần: phần cứng, phần mềm, cơ sở dữ liệu, mạng, quy trình.

9. An toàn thông tin (Information Security) là gì?

- Bảo vệ chống truy nhập, sử dụng, tiết lộ, sửa đổi, phá hủy thông tin trái phép.

10. Hai lĩnh vực chính của ATTT:

- **An toàn công nghệ thông tin (IT Security):** Áp dụng cho hệ thống công nghệ.
- **Đảm bảo thông tin (Information Assurance):** Đảm bảo thông tin không mất khi sự cố, sử dụng dự phòng ngoại vi.

11. Các thành phần của ATTT:

- An toàn máy tính và dữ liệu.
- An ninh mạng.
- Quản lý ATTT.
- Chính sách ATTT.

12. An toàn hệ thống thông tin (ISS):

- Đảm bảo các thuộc tính an ninh an toàn của hệ thống thông tin:
 - **Bí mật (Confidentiality).**
 - **Toàn vẹn (Integrity).**
 - **Sẵn dùng (Availability).**

2. Các yêu cầu an toàn hệ thống thông tin

1. **Tính bí mật (Confidentiality):** Chỉ người dùng có thẩm quyền mới được truy nhập thông tin.
 - Gồm: dữ liệu riêng tư, sở hữu trí tuệ, an ninh quốc gia.
 - Đảm bảo bằng kênh mã hóa VPN.
2. **Tính toàn vẹn (Integrity):** Thông tin chỉ có thể được sửa đổi bởi người có thẩm quyền.
 - Liên quan đến tính hợp lệ (validity) và chính xác (accuracy) của dữ liệu.
 - Thông tin phải không bị thay đổi, hợp lệ và chính xác.
3. **Tính sẵn dùng (Availability):** Thông tin có thể truy nhập bởi người dùng hợp pháp bất cứ khi nào họ có yêu cầu.
 - Đo bằng Uptime, Downtime, tỷ lệ phục vụ, thời gian giữa các sự cố, thời gian sửa chữa, thời gian phục hồi.

3. Bẫy vùng trong cơ sở hạ tầng CNTT và các mối đe dọa

1. Bẫy vùng:

- Vùng người dùng (User domain).
- Vùng máy trạm (Workstation domain).
- Vùng mạng LAN (LAN domain).
- Vùng LAN-to-WAN (LAN-to-WAN domain).
- Vùng WAN (WAN domain).
- Vùng truy nhập từ xa (Remote Access domain).
- Vùng hệ thống/ứng dụng (Systems/Applications domain).

2. Các đe dọa cụ thể với từng vùng:

- **Vùng người dùng:**
 - Thiếu ý thức, coi nhẹ chính sách, vi phạm chính sách.
 - Đưa CD/DVD/USB, tải file, phá hoại, tấn công từ nhân viên.
- **Vùng máy trạm:**
 - Truy nhập trái phép vào máy trạm, ứng dụng, dữ liệu.
 - Lỗi hỏng hệ điều hành, phần mềm.
 - Virus, mã độc.
 - Đưa CD/DVD/USB, tải file.
- **Vùng mạng LAN:**
 - Truy nhập trái phép vào LAN, ứng dụng, dữ liệu.
 - Lỗi hỏng hệ điều hành, phần mềm máy chủ.

- Giả mạo trong mạng WLAN, nguy cơ mất tính bí mật dữ liệu.
- Không tuân thủ các hướng dẫn và chuẩn cấu hình.
- **Vùng LAN-to-WAN:**
 - Thăm dò, rà quét cổng dịch vụ, truy nhập trái phép.
 - Lỗ hổng trong bộ định tuyến, tường lửa.
 - Tải file từ nguồn không xác định.
- **Vùng WAN:**
 - Rủi ro truy nhập trong môi trường công cộng.
 - Dữ liệu truyền dạng rõ (plaintext).
 - Nghe trộm, phá hoại, tấn công từ chối dịch vụ, tấn công DDoS, Email có chứa mã độc.
- **Vùng truy nhập từ xa**
 - Tấn công vét cạn vào mật khẩu, tên người dùng
 - Tấn công vào hệ thống đăng nhập, truy cập trái phép
 - Mất thông tin bí mật, lộ lọt dữ liệu
- **Vùng hệ thống/ứng dụng:**
 - Truy nhập trái phép đến trung tâm dữ liệu, phòng máy, tủ cáp.
 - Khó quản lý máy chủ yêu cầu sẵn dùng cao, Lỗ hổng phần mềm
 - Vấn đề an ninh trong môi trường ảo của điện toán đám mây, Hồng học, mất mát dữ liệu

4. Mô hình tổng quát đảm bảo an toàn hệ thống thông tin

1. Nguyên tắc đảm bảo an toàn:

- Phòng vệ nhiều lớp có chiều sâu (Defence in Depth).
- Không tồn tại HTTT an toàn tuyệt đối, cần cân bằng giữa an toàn, tính hữu dụng và chi phí.

2. Cần cân bằng giữa:

- Tính hữu dụng, Chi phí, tính an toàn

3. Mô hình Layered Security Model/Defence in Depth:

- Tạo nhiều lớp phòng vệ, kết hợp tác dụng của các lớp.

4. Các lớp phòng vệ điển hình:

- An ninh cơ quan/tổ chức (Plant Security): bảo vệ vật lý, chính sách.
- An ninh mạng (Network Security): lớp an ninh cho từng thành phần, tường lửa, VPN.
- An ninh hệ thống (System Security): tăng cường, quản lý tài khoản, bản vá, phát hiện phần mềm độc hại.

Câu hỏi 1:

Trong an toàn thông tin, ba thuộc tính quan trọng nhất cần được bảo vệ là gì?

- A) Tính khả dụng, tính linh hoạt và tính mở rộng
- B) Tính riêng tư, tính tin cậy và tính cập nhật
- C) **Tính bí mật, tính toàn vẹn và tính sẵn dùng**
- D) Tính bảo mật, tính xác thực và tính minh bạch

Câu hỏi 2:

Trong cơ sở hạ tầng CNTT, có bao nhiêu vùng thường được xác định, và vùng nào được coi là

nguy hiểm nhất do tính chất kết nối rộng mở của nó?

- A) Năm vùng; vùng LAN
- B) **Bảy vùng; vùng WAN**
- C) Sáu vùng; vùng DMZ
- D) Tám vùng; vùng người dùng

Câu hỏi 3:

Mô hình nào thường được sử dụng để đảm bảo an toàn một cách tổng quát, kết hợp các nguyên tắc an toàn cơ bản bằng việc thiết lập nhiều lớp bảo vệ?

- A) Mô hình một lớp duy nhất (single-layer model)
- B) **Mô hình đa lớp (layered model)**
- C) Mô hình bảo vệ ngẫu nhiên (random security model)
- D) Mô hình bảo vệ tuyệt đối (absolute security model)

Lý giải thêm để củng cố kiến thức:

- **Câu 1:** Ba thuộc tính "bí mật," "toàn vẹn," và "sẵn dùng" (hay còn gọi là CIA Triad - Confidentiality, Integrity, Availability) là nền tảng trong bảo mật thông tin, quyết định mục tiêu chính của mọi biện pháp an toàn.
- **Câu 2:** Việc có bảy vùng được xác định trong cơ sở hạ tầng CNTT giúp phân tích và xây dựng các biện pháp an ninh cụ thể cho từng vùng. Vùng WAN được đánh giá nguy hiểm nhất vì nó thường xuyên tiếp xúc với mạng Internet, tăng cơ hội bị tấn công từ bên ngoài.
- **Câu 3:** Mô hình đa lớp, hay phòng vệ chiều sâu, nhằm ngăn chặn và giảm thiểu rủi ro khi một lớp bảo vệ bị vượt qua, tăng cường mức độ bảo vệ tổng thể của hệ thống.

CHƯƠNG 2: CÁC DẠNG TẤN CÔNG VÀ CÁC PHẦN MỀM ĐỘC HẠI

I. 2.1. Khái Quát Về Môi Đe Dọa, Điểm Yếu, Lỗ Hổng và Tấn Công

1. Môi đe dọa (Threat):

- Định nghĩa: Là bất kỳ hành động nào có khả năng gây tổn hại đến các tài nguyên của hệ thống (phần cứng, phần mềm, cơ sở dữ liệu (CSDL), tập tin, dữ liệu hoặc hạ tầng mạng vật lý).
- Ví dụ: một người dùng vô tình xóa một file quan trọng, một hacker xâm nhập và đánh cắp dữ liệu, một sự cố mất điện làm hỏng phần cứng máy chủ,...

2. Điểm yếu (Weakness):

- Định nghĩa: Là lỗi hoặc khiếm khuyết tồn tại trong hệ thống.
- Đặc điểm: Các hệ thống luôn tồn tại các điểm yếu.
- Ví dụ: một phần mềm có lỗi lập trình, một cấu hình hệ thống không an toàn, một nhân viên không tuân thủ quy trình bảo mật...

3. **Lỗ hổng (Vulnerability):**

- Định nghĩa: Là bất kỳ điểm yếu nào trong hệ thống mà mối đe dọa có thể lợi dụng để gây hại.
- Ví dụ: lỗi tràn bộ đệm, lỗi SQL injection, các cổng dịch vụ mở không cần thiết,...

4. **Mối quan hệ giữa Mối đe dọa và Lỗ hổng:**

- Mối đe dọa thường khai thác lỗ hổng đã biết để tấn công phá hoại.
- Nếu tồn tại lỗ hổng, mối đe dọa có khả năng trở thành hiện thực.
- Không thể loại bỏ hết mối đe dọa nhưng có thể giảm thiểu lỗ hổng để giảm khả năng bị tấn công.

5. **Các mối đe dọa thường gặp:**

- Phần mềm độc hại
- Hư hỏng phần cứng hoặc phần mềm
- Kẻ tấn công ở bên trong (insider)
- Mất trộm thiết bị
- Kẻ tấn công ở bên ngoài (outsider)
- Tai họa thiên nhiên
- Gián điệp công nghiệp
- Khủng bố phá hoại.

6. **Tính chất của mối đe dọa:**

- Không phải tất cả các mối đe dọa đều độc hại (malicious).
- Một số là cố ý, một số là ngẫu nhiên/vô tình.

7. **Các lỗ hổng tồn tại ở các vùng:**

- Trong 7 vùng của nền tảng CNTT:
 - Vùng người dùng
 - Vùng máy trạm
 - Vùng mạng LAN
 - Vùng LAN-to-WAN
 - Vùng WAN
 - Vùng truy nhập từ xa
 - Vùng hệ thống/ứng dụng
- Trong hệ điều hành và phần mềm ứng dụng:
 - Lỗi tràn bộ đệm (buffer overflows)
 - Không kiểm tra đầu vào (unvalidated input)
 - Các vấn đề về điều khiển truy cập (access-control problems)
 - Các điểm yếu trong xác thực, ủy quyền (weaknesses in authentication, authorization)
 - Các điểm yếu trong các hệ mật mã (weaknesses in cryptographic practices)

8. **Tấn công độc hại/phá hoại (Malicious attacks):**

- Định nghĩa: Là một cuộc tấn công vào hệ thống máy tính hoặc tài nguyên mạng bằng cách khai thác lỗ hổng.
- Công thức: Tấn công = Mối đe dọa + Lỗ hổng

9. **Các loại tấn công (4 loại chính):**

- Giả mạo (Fabrications): Giả mạo thông tin để đánh lừa người dùng.
- Chặn bắt (Interceptions): Nghe trộm trên đường truyền và chuyển hướng thông tin.
- Gây ngắt quãng (Interruptions): Ngắt kênh truyền thông.
- Sửa đổi (Modifications): Sửa đổi thông tin trên đường truyền hoặc sửa đổi dữ liệu tập tin.

10. Hai kiểu tấn công:

- Tấn công chủ động (Active attacks):
 - Sửa đổi dữ liệu trên đường truyền
 - Sửa đổi dữ liệu trong tập tin
 - Giành quyền truy nhập trái phép vào máy tính hoặc hệ thống mạng
 - Là một sự đột nhập (intrusion) về mặt vật lý.
- Tấn công thụ động (Passive attacks):
 - Không gây ra thay đổi trên hệ thống
 - Nghe lén
 - Giám sát lưu lượng trên đường truyền.

11. Một số dạng tấn công điển hình:

- Tấn công vào mật khẩu
- Tấn công bằng mã độc
- Tấn công từ chối dịch vụ
- Tấn công giả mạo địa chỉ, nghe trộm
- Tấn công kiểu phát lại và người đứng giữa
- Tấn công bằng bom thư và thư rác
- Tấn công sử dụng cửa hậu
- Tấn công kiểu Social Engineering
- Tấn công phishing, pharming

II. 2.2. Các Công Cụ Hỗ Trợ Tấn Công

1. **Định nghĩa:** Là các công cụ phần cứng, phần mềm hoặc kỹ thuật hỗ trợ kẻ tấn công (attacker) xâm nhập vào hệ thống máy tính hoặc tài nguyên mạng.

2. Một số công cụ và kỹ thuật:

- Công cụ quét lỗ hổng (Vulnerability scanners):
 - Thu thập thông tin về điểm yếu/lỗ hổng đã biết.
 - Gửi thông điệp đặc biệt để kiểm tra lỗ hổng.
 - Kẻ tấn công dùng kết quả để quyết định dạng tấn công hiệu quả nhất.
- Công cụ quét cổng dịch vụ (Port scanners):
 - Các cổng TCP/IP, UDP (0-65535).
 - Cổng 0-1024 là cổng chuẩn, lớn hơn 1024 là cổng tùy gán.
 - Kẻ tấn công quét cổng để nhận diện điểm yếu.
 - Xác định cổng nào mở và dịch vụ đang chạy (VD: 80/443: web, 25: email SMTP, 1433: MS SQL Server, 53: DNS)
- Công cụ nghe lén (Sniffers):
 - Bắt gói tin khi truyền trên mạng.
 - Có thể là phần cứng, phần mềm hoặc kết hợp.
 - Thông tin nhạy cảm (mật khẩu) có thể bị đánh cắp nếu không mã hóa.
- Công cụ ghi phím gõ (Keyloggers):
 - Giám sát và ghi lại phím người dùng gõ.
 - Có thể là phần cứng hoặc phần mềm.
 - Dữ liệu ghi có thể gửi cho kẻ tấn công.
 - Người quản lý cũng có thể cài đặt keylogger để theo dõi nhân viên.

3. Một số công cụ quét lỗ hổng cho người quản trị:

* Microsoft Baseline Security Analyzer (đã được thay bằng Microsoft Defender Security

Center and Microsoft Defender Advanced Threat Protection (ATP))

* Nessus vulnerability scanner

* Acunetix Web Vulnerability Scanner

4. **Nguyên tắc tối thiểu các cổng được mở:**

- Đóng tất cả các cổng không sử dụng.
- Chỉ mở những cổng có dịch vụ cần thiết.

5. **Một số công cụ quét cổng:**

- Nmap
- PortswEEP
- Advanced Port Scanner
- Angry IP Scanner
- Superscan
- NetScanTools

6. **Một số công cụ bắt gói tin:**

- Tcpdump
- Pcap / Wincap
- IP Tools
- Wireshark

7. **Cài đặt Keyloggers:**

- Bằng phần cứng: thường được cài như 1 khớp nối kéo dài giữa máy tính và dây bàn phím.
- Bằng phần mềm: kẻ tấn công có thể tích hợp công cụ Keylogger vào một phần mềm thông thường và lừa người dùng cài đặt.

III. 2.3. Các Dạng Tấn Công Phá Hoại Thường Gặp

1. **Các dạng tấn công được liệt kê ở 2.1** (Tấn công vào mật khẩu, tấn công bằng mã độc, tấn công từ chối dịch vụ, tấn công giả mạo địa chỉ, tấn công nghe trộm, tấn công kiểu người đứng giữa, tấn công bằng bom thư và thư rác, tấn công sử dụng cửa hậu, tấn công kiểu Social Engineering, tấn công phishing, pharming). Phần này sẽ đi chi tiết từng dạng

2. **Tấn công vào mật khẩu:**

- Mục đích: Đánh cắp mật khẩu và thông tin tài khoản để lạm dụng.
- Nguy cơ: Mật khẩu không mã hóa dễ bị đánh cắp trên đường truyền.
- Các hình thức tấn công:
 - Tấn công dựa trên từ điển: Thử các từ trong từ điển.
 - Tấn công vét cạn (brute force): Thử tất cả tổ hợp ký tự.
- Phòng chống:
 - Mật khẩu mạnh: độ dài ≥ 8 ký tự (chữ hoa, thường, số và ký tự đặc biệt)
 - Thay đổi mật khẩu định kỳ.
- Một số công cụ khôi phục mật khẩu:
 - Password Cracker
 - Ophcrack
 - Offline NT Password & Registry Editor
 - PC Login Now
 - L0phtCrack
 - John the Ripper

3. **Tấn công bằng mã độc:**

* Các hình thức:

- Lợi dụng các lỗ hổng về lập trình, cấu hình.
 - Tấn công lợi dụng lỗi tràn bộ đệm (Buffer Overflow): Ghi dữ liệu vượt quá bộ nhớ đệm.
 - Có thể khiến ứng dụng ngừng hoạt động, gây mất dữ liệu, hoặc giúp kẻ tấn công kiểm soát hệ thống.
 - Có 3 vùng nhớ chứa bộ đệm: ngăn xếp(Stack) lưu tham số gọi hàm, phương thức và dữ liệu cục bộ; các biến cục bộ được cấp phát tĩnh, vùng nhớ heap(là vùng nhớ chung lưu dữ liệu, bộ nhớ heap được cấp phát động theo yêu cầu)
 - Giải thích cơ chế lỗi tràn bộ đệm trên bộ nhớ Stack và khả năng khai thác lỗ hổng theo tài liệu "Smashing the Stack" của tác giả Mark Shaneck
 - Các biện pháp phòng chống:
 - Kiểm tra mã nguồn bằng tay, sử dụng công cụ phân tích mã, đặt cơ chế không cho thực hiện mã trong Stack, sử dụng cơ chế bảo vệ Stack (canary), sử dụng các thư viện an toàn hoặc ngôn ngữ không tràn
 -
 -
 - Tấn công lợi dụng lỗi không kiểm tra đầu vào (unvalidated input):
 - * Nguy cơ: Cố tình nhập dữ liệu sai định dạng, chèn mã độc vào dữ liệu đầu vào.
 - * Các loại dữ liệu cần kiểm tra: dữ liệu text, lệnh qua URL, file, đối số trong dòng lệnh, dữ liệu từ mạng
 - * Các dạng tấn công: nhập dữ liệu quá lớn/sai định dạng, chèn mã khai thác
 - Tấn công chèn mã SQL (SQL Injection): Chèn mã SQL vào dữ liệu để thực hiện trên máy chủ CSDL
 - Nguyên nhân: dữ liệu đầu vào không được kiểm tra kỹ
 - Tùy mức độ có thể: vượt qua khâu xác thực, chèn/xóa dữ liệu, đánh cắp thông tin, chiếm quyền điều khiển hệ thống
 - SQL injection vượt qua xác thực người dùng: ví dụ form HTML đăng nhập có lỗ hổng khi nhập vào "aaaa' OR 1=1--" để bỏ qua phần kiểm tra pass
 - SQL Injection - Sửa đổi, hoặc xóa dữ liệu: ví dụ form HTML tìm kiếm sản phẩm có lỗ hổng, khi người dùng nhập vào "Samsung Galaxy S4'; DELETE FROM tbl_products;--" để xóa tất cả sản phẩm
 - SQL Injection - Đánh cắp thông tin: Tìm lỗ hổng, thăm dò CSDL (phiên bản), trích xuất thông tin, dùng UNION SELECT
 - SQL Injection - Chiếm quyền điều khiển: chèn mã để chạy thủ tục hệ thống (ví dụ: sp_send_dbmail, xp_cmdshell), xóa bảng, xóa CSDL, tạo tài khoản, đổi mật khẩu
 - Phòng chống: kiểm tra và lọc dữ liệu đầu vào, sử dụng thủ tục trong CSDL, thiết lập quyền truy nhập phù hợp, sử dụng các công cụ rà quét lỗ hổng

○

- Lừa người sử dụng tải, cài đặt và thực hiện các phần mềm độc hại: Virus, Trojan, Adware, Spyware.
4. **Tấn công từ chối dịch vụ (DoS - Denial of Service Attacks):**
- Định nghĩa: Cản trở người dùng hợp pháp truy nhập vào tài nguyên hệ thống.
 - Hai loại chính:
 - Tấn công logic: Dựa vào lỗi phần mềm làm dịch vụ ngừng hoạt động hoặc giảm hiệu năng.
 - Cần cài đặt bản cập nhật thường xuyên
 - Tấn công ngập lụt (Flooding): Gửi lượng lớn yêu cầu làm cạn kiệt tài nguyên hoặc băng thông.
 - Kỹ thuật ngập lụt:
 - SYN floods:
 - Kẻ tấn công gửi SYN-REQ, máy nạn nhân ghi nhận, nhưng không nhận ACK, làm đầy bảng kết nối.
 - Kẻ tấn công thường dùng địa chỉ IP giả mạo.
 - Mục đích: Làm cạn kiệt tài nguyên bộ nhớ, gây nghẽn mạng.
 - Phòng chống: Lọc, tăng kích thước Backlog, giảm thời gian chờ (SYN-RECEIVED Timer), SYN cache, sử dụng Firewall, Proxies
 - Smurf:
 - Kẻ tấn công gửi quảng bá ICMP (Ping) đến một mạng, địa chỉ IP nguồn là địa chỉ máy nạn nhân.
 - Các máy trong mạng trả lời đến máy nạn nhân làm ngập lụt đường truyền.
 - Phòng chống: Cấu hình máy/router không trả lời ICMP/quảng bá, không chuyển tiếp yêu cầu đến địa chỉ quảng bá.
 - Tấn công DDoS (Distributed Denial of Service):
 - Gây ngập lụt máy nạn nhân với một lượng lớn yêu cầu kết nối giả mạo từ nhiều máy
 - Kẻ tấn công chiếm quyền điều khiển hàng trăm, thậm chí hàng ngàn máy tính (Automated Agents)
 - Lượng yêu cầu giả mạo lớn, khó đối phó và tìm ra kẻ tấn công
 - Tấn công Reflective DDoS:
 - Các máy tính do kẻ tấn công điều khiển không trực tiếp tấn công máy nạn nhân
 - Gửi yêu cầu giả mạo đến các máy khác (Reflectors), các Reflectors trả lời về địa chỉ của máy nạn nhân.
 - Khó lần vết và phòng chống hơn DDoS thông thường
5. **Tấn công giả mạo địa chỉ IP (IP Spoofing):**
- Sử dụng địa chỉ IP giả để đánh lừa máy nạn nhân.
 - Nếu địa chỉ giả là địa chỉ LAN, kẻ tấn công dễ xâm nhập vào các máy khác trong LAN.
 - Nguy cơ: Nếu router/firewall không phát hiện ra IP giả mạo.
6. **Tấn công nghe lén (Sniffing/Eavesdropping):**
- Sử dụng thiết bị/phần mềm để bắt gói tin trên mạng (card mạng, hub, router)

- Có thể đánh cắp thông tin nhạy cảm (mật khẩu) nếu không mã hóa.
- * **Tấn công kiểu người đứng giữa (Man in the middle):**
- * Lợi dụng quá trình chuyển gói tin qua nhiều trạm.
- * Kẻ tấn công chặn bắt thông điệp giữa 2 bên và chuyển lại cho bên kia.
- * Sử dụng để đánh cắp thông tin.

content_copy Use code [with caution](#).

1. Tấn công bằng bom thư và thư rác:

- Bom thư: Chuyển một lượng lớn email đến nạn nhân gây ra tấn công DoS
- Thư rác: Email không mong muốn (quảng cáo). Gây lãng phí tài nguyên, có thể chứa phần mềm độc hại.
- Kẻ tấn công có thể lợi dụng các máy chủ email không được cấu hình tốt để gửi email.

2. Tấn công kiểu Social Engineering:

- Sử dụng kỹ thuật xã hội để thuyết phục người dùng tiết lộ thông tin.
- Kẻ tấn công giả danh người có vị trí cao hơn hoặc được ủy quyền, lập trang web giả
- Ví dụ: Trò lừa đảo Nigeria 4-1-9 (lợi dụng lòng tham)

3. Tấn công kiểu phishing:

- Lừa người dùng lấy thông tin cá nhân, tài khoản, thẻ tín dụng
- Giả mạo trang web các tổ chức tài chính, gửi email yêu cầu xác thực
- Nếu người dùng làm theo hướng dẫn sẽ cung cấp thông tin cho kẻ tấn công

4. Tấn công kiểu pharming:

- Tấn công vào trình duyệt người dùng
- Khi người dùng gõ địa chỉ 1 website, trình duyệt lại yêu cầu 1 website khác (độc hại)
- Kẻ tấn công thường dùng sâu, virus, phần mềm độc hại cài vào hệ thống
- Tấn công vào DNS để thay đổi địa chỉ IP

* **Tấn công APT (Advanced Persistent Threat)**

- * Tấn công có chủ đích, tập trung, thiết kế riêng cho từng mục tiêu
- * Hai thuộc tính quan trọng:
 - * Tiên tiến, cao cấp: kỹ thuật tiên tiến, bài bản
 - * Kiên trì, dai dẳng: thực hiện tấn công, ẩn mình, khai thác theo từng giai đoạn
- * Các giai đoạn điển hình: truy cập ban đầu, thâm nhập lần đầu và triển khai mã độc, mở rộng truy cập, giai đoạn tấn công, gây thiệt hại, tấn công tiếp theo.

content_copy Use code [with caution](#).

IV. 2.4. Các Dạng Phần Mềm Độc Hại

1. Phân loại:

- Cần chương trình chủ: back doors, logic bombs, trojan horses, viruses
- Không cần chương trình chủ: worms, zombie

2. Logic bombs:

- "Nhúng" vào chương trình bình thường.
- Hẹn giờ "phát nổ" khi một điều kiện cụ thể xảy ra.
- Hậu quả: Xóa dữ liệu, file, hệ thống.
- Ví dụ: Quả bom logic do Tim Lloyd cài tại công ty Omega Engineering xóa sạch các bản thiết kế và các chương trình, gây thiệt hại 10 triệu USD.

3. Trojan horses:

- Chứa mã độc, giả danh chương trình có ích.
- Thường dùng để thực thi gián tiếp tác vụ.
- Ví dụ: user A tạo trojan đặt ở thư mục chung, user B chạy, trojan sẽ cho user A quyền truy cập vào file của user B

4. Tấn công sử dụng cửa hậu (Back doors):

- Thường được tạo ra bởi lập trình viên để gỡ rối và test chương trình.
- Cho phép truy nhập trực tiếp vào hệ thống mà không cần thủ tục kiểm tra an ninh.
- Khó phát hiện, chỉ kích hoạt trong một ngữ cảnh nào đó.

5. Viruses:

- "Nhiễm" vào chương trình khác bằng cách sửa đổi chúng.
- Tự nhân bản, lây nhiễm khi chương trình bị nhiễm được kích hoạt
- Có thể thực hiện mọi việc mà chương trình có thể làm
- Con đường lây nhiễm: sao chép file, email, qua mạng...
- Giai đoạn của virus: nằm im, phát tán, kích hoạt, thực hiện
- Cơ chế chèn mã vào chương trình: đầu hoặc cuối chương trình. Khi chương trình bị nhiễm chạy mã virus thực hiện trước
- Các loại virus: file viruses, boot viruses, macro viruses, email viruses
 - File viruses: nhắm đến file chương trình hoặc file dữ liệu
 - Boot viruses: lây vào cung khởi động, luôn được nạp vào bộ nhớ
 - Macro viruses: lây vào file tài liệu MS Word và các ứng dụng Office, tự động kích hoạt nhờ auto-executed macros (AutoExecute, Automacro, Command macro)
 - Email viruses: tự gửi đến địa chỉ email trong sổ địa chỉ
-

6. Worms (Sâu):

- Tự lây nhiễm từ máy này sang máy khác mà không cần người dùng trợ giúp
- Sử dụng máy bị nhiễm làm "bàn đạp" để tấn công máy khác.
- Lây lan qua mạng, tương tự virus khi hoạt động.
- Phương thức lây lan: qua thư điện tử, thực thi từ xa, log-in từ xa
- Ví dụ: Code Red, Nimda

7. Zombie/Bot:

- Chương trình giành quyền kiểm soát máy tính, dùng máy đó để tấn công hệ thống khác.
- Dùng để tấn công DDoS máy chủ/website lớn.
- Tin tặc dùng bot để chiếm nhiều máy tính tạo thành mạng botnet, dùng để gửi

spam và DDoS.

- Khó lần vết và phát hiện.
- Tự lây nhiễm sang các hệ thống khác mà không cần chương trình chủ, vật chủ.
- Botnet được điều khiển qua máy chủ lệnh (Command and Control - C&C), giao thức HTTP hoặc IRC.

8. Rootkit:

- Phần mềm độc hại để giành quyền truy nhập hệ thống
- Che giấu bằng cách đội lốt phần mềm khác
- Được cài đặt tự động, hoặc tin tặc cài đặt khi chiếm quyền quản trị
- Rootkit có toàn quyền truy nhập vào các thành phần trong hệ thống và khó phát hiện

9. Adware và Spyware

- Adware: phần mềm tự hiển thị quảng cáo, có thể đi kèm với phần mềm miễn phí, có thể coi là độc hại nếu tự cài đặt và kích hoạt không có sự đồng ý của người dùng
- Spyware: phần mềm giám sát, thu thập thông tin nhạy cảm, cài đặt tự động hoặc bằng nhiều cách, có khả năng ẩn mình nên rất khó phát hiện
- Các loại spyware: system monitor, trojan, Adware, tracking cookies

10. Phòng chống:

- Ngăn chặn virus: cập nhật hệ thống, kiểm soát truy nhập.
- Khi đã nhiễm: phát hiện, nhận dạng, loại bỏ virus.
- Một số phần mềm diệt virus: Microsoft Security Essentials, Semantec Norton Antivirus, Kaspersky Antivirus, BitDefender Antivirus, AVG Antivirus, McAfee VirusScan, Trend Micro Antivirus, F-secure, BKAV Antivirus

NỘI DUNG 3 - ĐẢM BẢO AN TOÀN THÔNG TIN DỰA TRÊN MÃ HÓA

1. Khái quát về mã hóa thông tin và ứng dụng:

1.1 Mã hóa thông tin là gì?

- **Định nghĩa theo Webster's Revised Unabridged Dictionary:** Cryptography là "hành động hoặc nghệ thuật viết các ký tự bí mật".
- **Định nghĩa theo Free Online Dictionary of Computing:** Cryptography là "mã hóa dữ liệu sao cho chỉ có thể được giải mã bởi một số người chỉ định".
- **Hệ mã hóa cơ bản:** Gồm 2 khâu:
 - Mã hóa (encryption): Biến bản rõ thành bản mã.
 - Giải mã (decryption): Biến bản mã trở lại thành bản rõ.
- **Thuật ngữ:**
 - **Thông tin chưa mã hóa (Unencrypted information):** Thông tin ở dạng có thể hiểu được, còn gọi là bản rõ (plaintext/cleartext).

- **Thông tin đã mã hóa (Encrypted information):** Thông tin ở dạng đã bị xáo trộn, còn gọi là bản mã (ciphertext/encrypted text).
- **Mã hóa (Encryption):** Hành động xáo trộn bản rõ để chuyển thành bản mã.
- **Giải mã (Decryption):** Hành động giải xáo trộn bản mã để chuyển thành bản rõ.
- **Thuật toán (Algorithm):** Phương pháp cụ thể dùng để mã hóa.
- **Bộ mã hóa (Cipher):** Giải thuật để mã hóa và giải mã.
- **Khóa/Chìa (Key):** Chuỗi ký tự được sử dụng trong giải thuật mã hóa và giải mã.
- **Mã hóa khóa bí mật (Secret key cryptography):** Sử dụng một khóa cho cả mã hóa và giải mã.
- **Mã hóa khóa công khai (Public key cryptography):** Sử dụng một cặp khóa, trong đó khóa công khai dùng để mã hóa và khóa bí mật để giải mã.
- **Không gian khóa (Keyspace):** Tổng số khóa có thể có của một hệ mã hóa. (Ví dụ: khóa 64 bit có không gian khóa là 2^{64})
- **Hàm băm (Hash function):** Ánh xạ dữ liệu có kích thước thay đổi thành dữ liệu có kích thước cố định.
- **Hàm băm 1 chiều (One-way hash function):** Dễ mã hóa nhưng khó giải mã.
- **Phá mã/Thám mã (Cryptanalysis):** Quá trình giải mã thông điệp đã mã hóa mà không cần biết giải thuật và khóa mã.

1.2 Vai trò của mã hóa trong ATTT:

- **Bí mật (Confidentiality):** Đảm bảo chỉ người có thẩm quyền mới truy cập được thông tin.
- **Toàn vẹn (Integrity):** Đảm bảo dữ liệu không bị sửa đổi trái phép.
- **Xác thực (Authentication):** Đảm bảo thông tin nhận dạng về các chủ thể tham gia phiên truyền thông là xác thực.
- **Không thể chối bỏ (Non-repudiation):** Ngăn chặn việc một chủ thể chối bỏ hành vi hoặc phát ngôn của mình.

1.3 Các thành phần của một hệ mã hóa:

- **Hệ mật mã (Cryptosystem):** Bản cài đặt của các kỹ thuật mật mã và các thành phần liên quan.
- **Thành phần:** Bản rõ, giải thuật mã hóa, bản mã, giải thuật giải mã, khóa mã hóa, khóa giải mã.
- **Không gian khóa:** Tập hợp tất cả các khóa có thể có; không gian khóa càng lớn, hệ mã hóa càng an toàn.

1.4 Lịch sử mã hóa:

- Các kỹ thuật mã hóa thô sơ có từ 4000 năm trước.
- Phát triển mạnh mẽ từ thế kỷ 1800 nhờ công cụ toán học, và vượt bậc trong thế kỷ 20 nhờ máy tính và CNTT.
- Sử dụng rộng rãi trong chiến tranh thế giới I và II.

- **1976:** Chuẩn mã hóa DES (Data Encryption Standard).
- **1976:** Khái niệm mã hóa bất đối xứng (Asymmetric key cryptography) hay mã hóa khóa công khai (Public key cryptography).
- **1977:** Giải thuật mã hóa khóa công khai RSA.
- **1991:** PGP (Pretty Good Privacy) ra đời.
- **2000:** Chuẩn mã hóa AES (Advanced Encryption Standard).

1.5 Mã hóa dòng và mã hóa khối:

- **Mã hóa dòng (Stream cipher):** Kết hợp từng bit (hoặc ký tự) của dữ liệu với từng bit (hoặc ký tự) của khóa.
- **Mã hóa khối (Block cipher):** Chia dữ liệu thành từng khối có kích thước cố định để mã hóa.
- **Các chế độ hoạt động của mã hóa khối:**
 - **ECB (Electronic Codebook):** Khối bản rõ giống nhau cho ra khối bản mã giống nhau.
 - **CBC (Cipher-Block Chaining):** Khối bản mã phụ thuộc khối rõ hiện tại và các khối rõ trước đó.
 - **CFB (Cipher Feedback):** Khối bản mã phụ thuộc khối rõ hiện tại và các khối rõ trước đó.
 - **OFB (Output Feedback):** Sinh luồng khóa và XOR với các khối mã để tạo bản mã.
-

1.6 Các tiêu chuẩn đánh giá hệ mã hóa:

- **Độ an toàn (level of security):** Đánh giá qua số lượng tính toán để phá được hệ mã hóa.
- **Tính năng (functionality):** Hệ thống có thể sử dụng cho nhiều mục đích bảo mật.
- **Chế độ hoạt động (methods of operation):** Cung cấp các tính năng khác nhau theo chế độ hoạt động.
- **Hiệu năng (performance):** Tốc độ mã hóa (bits/giây).
- **Độ dễ cài đặt (ease of implementation):** Độ khó cài đặt thuật toán.

1.7 Ứng dụng của mã hóa:

- Dịch vụ xác thực (Kerberos, RADIUS,...)
- Điều khiển truy cập
- Đánh giá và phân tích logs
- Sản phẩm quản lý ATTT
- Đảm bảo an toàn cho truyền thông không dây
- Nền tảng bảo mật (PKI, PGP)

- Giao thức bảo mật (SSL/TLS, SSH, SET, IPSec)
- Hệ thống (VPN).

2. Các phương pháp mã hóa:

2.1 Phương pháp thay thế:

- Thay thế một giá trị bằng một giá trị khác (ký tự bằng ký tự, bit bằng bit).
- **Caesar cipher:** Dịch 3 chữ sang phải.
- Có thể có nhiều bộ chữ mã.

2.2 Phương pháp đổi chỗ:

- Sắp xếp lại các giá trị trong một khối để tạo bản mã (bit hoặc byte).
- Thực hiện đổi chỗ theo một quy tắc nhất định.

2.3 Phương pháp XOR:

- Sử dụng phép toán logic XOR để tạo bản mã (từng bit của bản rõ XOR với bit tương ứng của khóa).
- Bảng giá trị chân thực của XOR.
- Ví dụ minh họa.

2.4 Phương pháp Vernam:

- Sử dụng một tập ký tự để nối vào ký tự của bản rõ để tạo bản mã (one-time pad).
- Mỗi ký tự trong tập chỉ dùng một lần trong một tiến trình mã hóa.
- Các ký tự của bản rõ và tập ký tự được chuyển thành số, cộng lại và lấy modulo 26 (đối với bảng chữ cái tiếng Anh).

2.5 Phương pháp sách hoặc khóa chạy:

- Mã hóa và giải mã sử dụng các khóa mã chứa trong các cuốn sách.
- Ví dụ: Sử dụng số trang, dòng, chữ cái trong một cuốn sách.

2.6 Phương pháp hàm băm:

- Tạo bản tóm tắt của thông điệp để nhận dạng và đảm bảo tính toàn vẹn.

- Các hàm băm là hàm công khai, đầu ra có chiều dài cố định.
- Một số hàm băm thông dụng: MD2, MD4, MD5, MD6, SHA0, SHA1, SHA2, SHA3, CRC32.

3. Các giải thuật mã hóa:

3.1 Các giải thuật mã hóa khóa đối xứng:

- **Định nghĩa:** Sử dụng một khóa duy nhất cho cả quá trình mã hóa và giải mã. Còn gọi là mã hóa khóa bí mật/khóa riêng.
- **Đặc điểm:** Kích thước khóa tương đối ngắn, tốc độ nhanh, độ an toàn cao nhưng khó khăn trong quản lý và phân phối khóa.
- **Các giải thuật:**
 - **DES:** Kích thước khối 64 bit, khóa 64 bit (thực tế 56 bit). Các bước: Hoán vị khởi tạo, 16 vòng lặp, hoán vị kết thúc. Hàm F (Fiestel): mở rộng, trộn khóa, thay thế, hoán vị. Tạo bộ khóa phụ thông qua PC1, PC2, quay trái bit. Giải mã ngược lại.
 - **Triple DES (3-DES):** Áp dụng DES 3 lần cho mỗi khối dữ liệu với bộ 3 khóa K1, K2, K3 (168 bit, 112 bit, 56 bit).
 - **AES:** Chuẩn mã hóa dữ liệu, kích thước khối 128 bit, khóa có thể 128, 192, 256 bit. Dựa trên mạng hoán vị - thay thế. Các bước: mở rộng khóa, vòng khởi tạo, vòng lặp chính (SubBytes, ShiftRows, MixColumns, AddRoundKey), vòng cuối (SubBytes, ShiftRows, AddRoundKey). Mở rộng khóa theo thủ tục Rijndael (Rotword, SubBytes, Rcon, ShiftRow).
-
- **Vấn đề của hệ mật mã khóa đối xứng:** Khó khăn trong trao đổi khóa, không đáp ứng yêu cầu xác thực và chống chối bỏ, khó quản lý khi nhiều người dùng.

3.2 Các giải thuật mã hóa khóa bất đối xứng:

- **Định nghĩa:** Sử dụng một cặp khóa (khóa công khai để mã hóa, khóa bí mật để giải mã).
- **Đặc điểm:** Kích thước khóa lớn, tốc độ chậm, độ an toàn cao, thuận lợi trong quản lý và phân phối khóa.
- **Các giải thuật:** RSA, Rabin, ElGamal, McEliece, Knapsack.
 - **RSA:** Độ an toàn dựa trên tính khó của phân tích số nguyên rất lớn. Thủ tục sinh khóa: tạo 2 số nguyên tố p, q; tính n, $\phi(n)$; chọn e, d. Mã hóa: $c = me \bmod n$; giải mã $m = cd \bmod n$. Các vấn đề: Chọn p, q không gần nhau và đủ lớn; số mũ nhỏ; cài đặt (java/c).
-

3.3 Các hàm băm:

- **Định nghĩa:** Hàm toán học h , ánh xạ chuỗi đầu vào x có chiều dài bất kỳ sang một chuỗi đầu ra $h(x)$ có chiều dài cố định n bit; để tính toán $h(x)$.
- **Phân loại theo khóa:** Hàm băm không khóa (MDC), hàm băm có khóa (MAC).
- **Phân loại theo tính năng:** Mã phát hiện sửa đổi (MDC) gồm: Hàm băm một chiều (OWHF) và hàm băm chống đụng độ (CRHF). Mã xác thực thông điệp (MAC).
- **Mô hình hàm băm:** xử lý qua các bước preprocessing, iterated processing, optional output transformation.
- **Các giải thuật hàm băm:** CRC, Checksums, MD2, MD4, MD5, MD6, SHA0, SHA1, SHA2, SHA3.
 - **MD5:** Chiều dài băm 128 bit, các bước: chia khối 512 bit, khởi tạo state 128 bit, 4 vòng (hàm F, cộng modulo, quay trái).
 - **SHA1:** Chiều dài băm 160 bit, tương tự MD5, sử dụng các thao tác add, and, or, xor, rotate, mod.

4. Chữ ký số, chứng chỉ số và PKI:

4.1 Chữ ký số:

- **Định nghĩa:** Chuỗi dữ liệu liên kết với một thông điệp và thực thể tạo ra thông điệp.
- **Giải thuật tạo chữ ký số:** Phương pháp sinh chữ ký số.
- **Giải thuật kiểm tra chữ ký số:** Phương pháp xác minh tính xác thực chữ ký số.
- **Hệ chữ ký số:** Gồm giải thuật tạo chữ ký và giải thuật kiểm tra chữ ký.
- **Quá trình tạo chữ ký:** Tính toán chuỗi đại diện, ký chuỗi đại diện bằng khóa riêng, ghép thông điệp và chữ ký.
- **Quá trình kiểm tra chữ ký:** Tách chữ ký, tính toán chuỗi đại diện, giải mã chữ ký bằng khóa công khai, so sánh.
- **Giải thuật chữ ký số RSA:** Sử dụng cả mã hóa và chữ ký số.
- **Giải thuật chữ ký số DSA:** Chuẩn chữ ký số, dùng cho xác thực.

4.2 Chứng chỉ số:

- **Định nghĩa:** Tài liệu điện tử sử dụng chữ ký số để liên kết khóa công khai và thông tin nhận dạng của thực thể.
- **Nội dung:** Serial Number, Subject, Signature Algorithm, Signature Hash Algorithm, Signature, Issuer, Valid-From, Valid-To, Key-Usage, Public Key, Thumbprint Algorithm, Thumbprint.
- **Nội dung trường Subject:** CN, OU, O, L, S, C.
- **Sử dụng:** An toàn giao dịch web (HTTPS), Email, FTP, xác thực.

4.3 Hạ tầng khóa công khai (PKI):

- **Định nghĩa:** Tập các phần cứng, phần mềm, nhân lực, chính sách để tạo, quản lý, phân phối, sử dụng, lưu trữ và thu hồi chứng chỉ số.
- **Thành phần:** Certificate Authority (CA), Registration Authority (RA), Validation Authority (VA), Central Directory (CD), Certificate Management System, Certificate Policy.

5. Quản lý khóa và phân phối khóa:

5.1 Giới thiệu về quản lý và phân phối khóa:

- **Quan hệ khóa (Keying relationship):** Các bên chia sẻ dữ liệu để sử dụng cho kỹ thuật mã hóa (khóa, giá trị khởi tạo,...).
- **Quản lý khóa (Key management):** Thiết lập và duy trì các quan hệ khóa.
- **Các kỹ thuật và thủ tục:** Khởi tạo người dùng, sinh khóa, phân phối, kiểm soát, cập nhật, thu hồi, lưu trữ.
- **Phân phối khóa (Key distribution):** Vận chuyển/trao đổi khóa mật mã.
- **Vai trò của quản lý khóa:** Bảo đảm bí mật, toàn vẹn, xác thực, không thể chối bỏ, chữ ký số.
- **Các mối đe dọa:** Lộ khóa, thỏa hiệp, sử dụng trái phép.
- **Chính sách an ninh:** Các thủ tục và trách nhiệm về quản lý khóa.
- **Phân loại lớp khóa:** Khóa chủ, khóa trao đổi, khóa dữ liệu.
- **Phân loại theo thời gian:** Khóa dài hạn, khóa ngắn hạn.

5.2 Các kỹ thuật phân phối khóa bí mật:

- **Vấn đề:** Phân phối n^2 khóa (khi có n người dùng).
- **Mô hình đơn giản:** Phân phối khóa điểm - điểm, trung tâm phân phối khóa (KDC), trung tâm dịch hóa (KTC).
 - **KDC:** Phân phối khóa tập trung, mỗi bên chia sẻ khóa dài hạn với KDC.
 - **KTC:** Cung cấp khóa phiên, mỗi bên chia sẻ khóa dài hạn với KTC.
 - **So sánh KDC và KTC:** KDC sinh khóa tập trung, KTC sinh khóa phân tán, cả hai đều cần máy chủ tin cậy.
-
- **Ưu/nhược điểm:**
 - **Ưu điểm:** Tiết kiệm lưu trữ khóa.
 - **Nhược điểm:** Mất an toàn, điểm nút cổ chai, dịch vụ ngừng nếu máy chủ trực trực, cần máy chủ trực tuyến.
-
- Sử dụng mã hóa khóa công khai để phân phối khóa bí mật.

5.3 Các kỹ thuật phân phối khóa công khai:

- Trao đổi trực tiếp qua kênh tin cậy.
- Truy nhập vào danh mục công cộng (public-key registry).
- Máy chủ trực tuyến tin cậy.
- Máy chủ không trực tuyến và chứng chỉ.

5.4 Giao thức xác thực Kerberos:

- Cung cấp xác thực thực thể và thiết lập khóa sử dụng mã hóa khóa đối xứng và bên thứ ba.
- Liên quan: Máy khách A, máy chủ B, máy chủ tin cậy T.
- A và B không chia sẻ khóa bí mật, nhưng T chia sẻ khóa bí mật dài hạn với A và B.
- Mục đích: B kiểm tra A.
- Mô tả vắn tắt: A yêu cầu T, T cấp khóa phiên và ticket cho A, A chuyển ticket cho B.
- Thủ tục xác thực: 4 bước ($A \rightarrow T$, $A \leftarrow T$, $A \rightarrow B$, $A \leftarrow B$), sử dụng các thuật ngữ (E, N, T, k, L). Các thao tác: sinh Na, sinh khóa k, mã hóa, giải mã, kiểm tra.

6. Các giao thức đảm bảo ATTT dựa trên mã hóa:

6.1 SSL/TLS (Secure Socket Layer/Transport Layer Security):

- SSL do Netscape phát minh (1993), TLS xây dựng dựa trên SSL 3.0 do IETF phê chuẩn (1999).
- **Đặc điểm:** Trao đổi khóa phiên bằng khóa công khai, mã hóa dữ liệu bằng khóa phiên, hàm băm có khóa (MAC) để đảm bảo toàn vẹn và xác thực, cần chứng chỉ số.
- **Các giao thức con:**
 - SSL Handshake Protocol: Bắt tay, trao đổi thông điệp xác thực, thiết lập thông số.
 - SSL Change Cipher Spec Protocol: Thiết lập bộ mã hóa.
 - SSL Alert Protocol: Cảnh báo.
 - SSL Record Protocol: Tạo đường hầm an toàn cho truyền thông.

6.2 SET (Secure Electronic Transactions):

- Cho phép thanh toán điện tử an toàn sử dụng thẻ tín dụng (Visa và MasterCard).
- Đảm bảo bí mật, toàn vẹn, xác thực tài khoản và nhà cung cấp.

6.3 PGP (Pretty Good Privacy):

- Do Philip Zimmermann phát triển (1991).
- Cung cấp tính riêng tư và xác thực.
- Sử dụng mã hóa khóa bí mật và khóa công khai, tạo/kiểm tra chữ ký số.

6.4 IPSec (IP Security):

- Cung cấp bảo mật cho lớp mạng IP.
- Sử dụng các giao thức: AH (Authentication Header), ESP (Encapsulating Security Payload).

6.5 SSH (Secure Shell):

- Giao thức truyền thông an toàn trên môi trường không an toàn.
- Cung cấp xác thực máy chủ, xác thực người dùng, và mã hóa phiên.

Tổng Kết:

Chương này đã trình bày chi tiết về các khái niệm cơ bản, các phương pháp, thuật toán và giao thức liên quan đến mã hóa thông tin, giúp đảm bảo an toàn thông tin trên đường truyền. Việc nắm vững những kiến thức này sẽ giúp bạn hiểu rõ về cách bảo vệ dữ liệu và truyền thông trên mạng một cách an toàn.

Hy vọng bản tóm tắt này sẽ giúp bạn chuẩn bị tốt cho sơ đồ tư duy và bài thuyết trình của mình. Nếu bạn có câu hỏi nào khác, hãy cứ hỏi nhé!

NỘI DUNG 4: CÁC KỸ THUẬT VÀ CÔNG CỤ ĐẢM BẢO AN TOÀN HTTP

Chương này tập trung vào các kỹ thuật và công cụ chính để bảo vệ hệ thống thông tin. Nội dung chính bao gồm:

1. Điều khiển truy nhập

- **Khái niệm:**
 - Điều khiển truy nhập là quá trình xác định và quản lý quyền truy cập của người dùng vào các thông tin, hệ thống và tài nguyên.
 - Một hệ thống điều khiển truy nhập thường bao gồm 3 dịch vụ chính:

- **Xác thực (Authentication):** Xác minh tính chân thực của thông tin nhận dạng người dùng cung cấp (ví dụ: tên đăng nhập và mật khẩu).
- **Trao quyền (Authorization):** Xác định tài nguyên người dùng được phép truy cập sau khi đã xác thực.
- **Quản trị (Administration):** Quản lý các tài khoản người dùng và quyền truy nhập của họ (thêm, xóa, sửa đổi).
-
- Mục đích chính: Đảm bảo tính bí mật (chỉ người có thẩm quyền được truy cập), tính toàn vẹn (dữ liệu không bị sửa đổi trái phép) và tính sẵn dùng (hệ thống luôn hoạt động để cung cấp dịch vụ cho người dùng hợp lệ).
-
- **Các biện pháp điều khiển truy nhập:**
 - **Điều khiển truy nhập tùy chọn (Discretionary Access Control - DAC):**
 - Hạn chế truy cập dựa trên thông tin nhận dạng của người dùng hoặc nhóm người dùng.
 - Thông tin nhận dạng: "Bạn là ai?" (CMND, bằng lái xe,...), "Bạn biết gì?" (tên đăng nhập, mật khẩu,...), "Bạn có gì?" (thẻ ATM, thẻ tín dụng,...).
 - Chủ sở hữu đối tượng (owner) có toàn quyền kiểm soát đối tượng, có thể cấp hoặc hủy quyền truy cập cho người dùng khác.
 - Ví dụ: Người dùng có thư mục riêng (home directory), có quyền tạo, sửa, xóa file, và cấp quyền truy cập cho người khác.
 - **Ma trận điều khiển truy nhập (Access Control Matrix - ACM):**
Mô tả quyền truy cập thông qua ma trận 2 chiều, với các thành phần:
 - **Chủ thể (Subject):** Người dùng, tiến trình muốn truy cập.
 - **Đối tượng (Object):** Tài nguyên cần bảo vệ (file, tiến trình,...).
 - **Quyền truy nhập:** Hành động chủ thể có thể thực hiện trên đối tượng (đọc, ghi, thực thi, sở hữu).
 -
 - **Danh sách điều khiển truy nhập (Access Control List - ACL):**
Danh sách các quyền truy cập của chủ thể với một đối tượng.
 - Mỗi bản ghi ACL có dạng (subject, operation).
 - Hệ điều hành kiểm tra ACL khi có yêu cầu truy cập.
 - ACL có thể áp dụng cho một hoặc một nhóm đối tượng.
 -
 - **Điều khiển truy nhập bắt buộc (Mandatory Access Control - MAC):**
 - Hạn chế truy cập dựa trên mức độ nhạy cảm của thông tin (gán nhãn) và quyền truy cập chính thức của chủ thể.
 - Các mức độ nhạy cảm: Tối mật (Top Secret - T), Tuyệt mật (Secret - S), Mật (Confidential - C), Không phân loại (Unclassified - U).
 - Người tạo đối tượng không có toàn quyền truy cập.
 - Quyền truy cập do người quản trị hệ thống định trước dựa trên chính sách an ninh.
 - Thường dùng trong các cơ quan an ninh, quân đội và ngân hàng.
 - **Mô hình Bell-LaPadula:** Mô hình bảo mật đa cấp, thường dùng

trong quân sự.

- Tài liệu và người dùng được gán các mức độ bảo mật khác nhau.
- **Nguyên tắc đọc xuống:** Người dùng chỉ được đọc tài liệu ở mức độ bảo mật bằng hoặc thấp hơn.
- **Nguyên tắc ghi lên:** Người dùng chỉ được ghi vào tài liệu ở mức độ bảo mật bằng hoặc cao hơn.

- - **Điều khiển truy nhập dựa trên vai trò (Role-Based Access Control - RBAC):**

- Truy nhập dựa trên vai trò của người dùng trong tổ chức.
- Có thể áp dụng cho nhóm hoặc cá nhân.
- Quyền truy nhập được tập hợp thành các "vai trò" khác nhau.
- Ví dụ: Trong trường học, nhóm quản lý có quyền truy cập tất cả, nhóm giáo viên có quyền truy cập CSDL môn học, nhóm sinh viên chỉ được xem nội dung môn học.
- Liên kết người dùng và vai trò: Người dùng được cấp "thẻ thành viên" cho các nhóm vai trò tương ứng.
- Quản lý vai trò phân cấp theo mô hình công ty/tổ chức.

- - **Điều khiển truy nhập dựa trên luật (Rule-Based Access Control):**

- Truy nhập dựa trên các luật được định nghĩa trước.
- Ví dụ: Cho phép truy cập dựa trên tên miền, địa chỉ IP.
- Firewalls/Proxies là ví dụ điển hình, sử dụng luật để lọc gói tin, file, website, nội dung.

- - **Một số công nghệ điều khiển truy nhập:**

- **Dựa trên mật khẩu:**

- Mỗi người dùng có tài khoản và mật khẩu.
- Mật khẩu có thể là nguyên bản (plain text) hoặc mã hóa (encrypted text) bằng các thuật toán như MD4, MD5, SHA-1, SHA256,...
- Mật khẩu có thể dùng nhiều lần hoặc một lần (one-time password - OTP).
- Độ bảo mật phụ thuộc vào độ khó đoán, độ dài và tuổi thọ của mật khẩu.
- **OTP (One-Time Password):** Sinh ngẫu nhiên, chỉ dùng một lần, an toàn hơn, tránh tấn công replay.

- **Dựa trên khóa mã:**

- Sử dụng thuật toán để đảm bảo bí mật và xác minh danh tính.
- **Chứng chỉ số (Digital Certificate):** Thông tin nhận dạng, khóa công khai của chủ thể, được mã hóa bởi tổ chức có thẩm quyền (Certificate Authority - CA).

- **Dựa trên thẻ thông minh (Smart card):**

- Thẻ nhựa có chip điện tử, có khả năng tính toán và mã hóa.
- Sử dụng 2 yếu tố xác thực: "Cái bạn có" (thẻ) và "Cái bạn biết" (PIN).

■

■ Dựa trên thẻ bài (token):

- Thiết bị cầm tay, có pin và bộ nhớ, lưu trữ mật khẩu hoặc thông tin khác.
- Có cơ chế xác thực 2 yếu tố như smartcard, nhưng năng lực tính toán mạnh hơn.

■

■ Dựa trên đặc điểm sinh trắc học:

- Nhận dạng chủ thẻ dựa trên dấu vân tay, tròng mắt, khuôn mặt, tiếng nói, chữ ký tay.
- Ưu điểm: Bảo mật cao, luôn đi cùng chủ thẻ.
- Nhược điểm: Chi phí đắt, đòi hỏi nhiều tính toán, tỷ lệ nhận dạng sai có thể cao.

■

○

2.

3. Tường lửa (Firewall)

○ Giới thiệu:

- Bảo vệ hệ thống và mạng cục bộ khỏi các đe dọa từ bên ngoài.
- Thường được đặt ở cổng vào của mạng nội bộ.
- Tất cả các gói tin đều phải đi qua tường lửa.
- Chỉ các gói tin hợp lệ được phép đi qua dựa trên chính sách an ninh.
- Tường lửa cần có khả năng miễn dịch với các cuộc tấn công.
- Có thể ngăn chặn các tấn công như IP spoofing.

○

○ Các loại tường lửa:

- **Lọc gói tin (Packet-Filtering):** Áp dụng luật cho mỗi gói tin để quyết định chuyển tiếp hay loại bỏ.
- **Cổng ứng dụng (Application-level gateway):** Còn gọi là proxy server, phát lại traffic của mức ứng dụng.
- **Cổng chuyển mạch (Circuit-level gateway):** Hoạt động tương tự bộ chuyển mạch.
- **Lọc có trạng thái (Stateful firewall):** Lưu trạng thái kết nối, chỉ cho phép gói tin thuộc kết nối đang hoạt động đi qua.
- **Lọc không trạng thái (Stateless firewall):** Chỉ lọc các gói tin riêng lẻ mà không quan tâm đến kết nối.

○

○ Kỹ thuật kiểm soát truy nhập của tường lửa:

- **Kiểm soát dịch vụ:** Xác định dịch vụ được phép truy nhập (đi vào/đi ra).
- **Kiểm soát hướng:** Điều khiển hướng đi của gói tin theo từng dịch vụ.
- **Kiểm soát người dùng:** Xác định người dùng được phép truy nhập.
- **Kiểm soát hành vi:** Kiểm soát việc sử dụng dịch vụ (ví dụ: lọc thư rác, hạn chế truy cập vào một phần trang web).

○

- **Hạn chế:**
 - Không chống được các cuộc tấn công không đi qua nó, hoặc các tấn công vào lỗi hỏng phần mềm.
 - Không ngăn chặn được hiểm họa từ bên trong.
 - Không ngăn chặn được việc vận chuyển file nhiễm virus hoặc phần mềm độc hại.

4.

5. Hệ thống phát hiện/ngăn chặn tấn công, đột nhập (IDS/IPS)

- **Khái niệm:**
 - IDS (Intrusion Detection System): Phát hiện các cuộc tấn công, đột nhập.
 - IPS (Intrusion Prevention System): Ngăn chặn các cuộc tấn công, đột nhập.
- **Nhiệm vụ chính:**
 - Giám sát lưu lượng mạng và hành vi hệ thống.
 - Nhận dạng dấu hiệu tấn công, đột nhập.
 - Ghi log các hành vi tấn công.
 - Ngăn chặn hành vi tấn công.
 - Thông báo cho quản trị viên.
- **So sánh IDS/IPS:**
 - Giống nhau: đều thực hiện giám sát.
 - Khác nhau:
 - IPS đặt giữa đường truyền, chủ động ngăn chặn tấn công.
 - IDS thường kết nối với bộ định tuyến, switch, card mạng, chủ yếu giám sát và cảnh báo, không tự ngăn chặn.
- **Phân loại theo nguồn dữ liệu:**
 - **Hệ thống phát hiện đột nhập mạng (NIDS):** Phân tích lưu lượng mạng.
 - **Hệ thống phát hiện đột nhập host (HIDS):** Phân tích sự kiện xảy ra trên một máy.
- **Phân loại theo kỹ thuật phân tích:**
 - **Dựa trên chữ ký:** So sánh với các dấu hiệu đã biết (cơ sở dữ liệu chữ ký).
 - **Dựa trên bất thường:** Phát hiện các hành vi khác thường so với hồ sơ bình thường.
- **NIDS - Snort:** Sử dụng luật để phát hiện tấn công trên lưu lượng mạng
 - **Quy trình:** Lưu lượng mạng -> Giải mã gói tin -> Tiền xử lý -> Mô tơ phát hiện -> Ghi log và cảnh báo -> Cảnh báo và log
- **HIDS - OSSEC:** Sử dụng agent để thu thập log trên máy chủ và gửi về server trung tâm để phân tích
- **Phát hiện đột nhập dựa trên chữ ký:**
 - Xây dựng cơ sở dữ liệu các dấu hiệu/chữ ký của các cuộc tấn công đã biết.
 - Giám sát và so sánh với cơ sở dữ liệu.

- Ưu điểm: Phát hiện hiệu quả các tấn công đã biết, tốc độ cao.
- Nhược điểm: Không phát hiện được các tấn công mới, đòi hỏi nhiều công sức cập nhật cơ sở dữ liệu.
-
- **Phát hiện đột nhập dựa trên bất thường:**
 - Dựa trên giả thiết: hành vi đột nhập có quan hệ chặt chẽ với hành vi bất thường.
 - Quá trình: Xây dựng hồ sơ (profile) đối tượng ở trạng thái bình thường -> Giám sát hành vi hiện tại -> So sánh với hồ sơ.
 - Ưu điểm: Có thể phát hiện các cuộc tấn công mới.
 - Nhược điểm: Tỷ lệ cảnh báo sai cao, tốn nhiều tài nguyên.
 - Các phương pháp xử lý và phân tích: Thống kê, học máy, khai phá dữ liệu, mạng nơ-ron.

Tóm lại:

Nội dung chương này cung cấp một cái nhìn tổng quan và chi tiết về các kỹ thuật và công cụ quan trọng để bảo vệ hệ thống thông tin. Bắt đầu từ việc kiểm soát truy cập của người dùng đến việc triển khai tường lửa để ngăn chặn các mối đe dọa từ bên ngoài, cùng với việc sử dụng IDS/IPS để phát hiện và ngăn chặn các cuộc tấn công. Các kỹ thuật phân loại, các ưu điểm và nhược điểm của từng phương pháp cũng được phân tích chi tiết, cung cấp một nền tảng vững chắc để hiểu rõ hơn về việc bảo vệ hệ thống thông tin.

Hy vọng bản tóm tắt này sẽ giúp ích cho bạn trong việc tạo sơ đồ tư duy và chuẩn bị bài thuyết trình của mình. Nếu bạn có bất kỳ câu hỏi nào hoặc cần làm rõ thêm bất kỳ phần nào, hãy cho tôi biết nhé!

Chương 5: QUẢN LÝ, CHÍNH SÁCH & PHÁP LUẬT ATTT

Chương này bao gồm các nội dung chính sau:

1. Quản lý an toàn thông tin (ATTT):

○ Khái quát về quản lý ATTT:

- **Tài sản ATTT:** Được định nghĩa là thông tin, thiết bị hoặc các thành phần khác hỗ trợ các hoạt động liên quan đến thông tin. Tài sản này có thể bao gồm phần cứng (máy chủ, thiết bị mạng), phần mềm (hệ điều hành, phần mềm máy chủ dịch vụ), và thông tin (thông tin khách hàng, nhà cung cấp, hoạt động kinh doanh).
- **Định nghĩa quản lý ATTT:** Quản lý ATTT là một tiến trình nhằm đảm bảo các tài sản quan trọng của tổ chức được bảo vệ đầy đủ với chi phí hợp lý.
- **Mục tiêu quản lý ATTT:** Trả lời 3 câu hỏi:
 - Những tài sản nào cần được bảo vệ?
 - Những đe dọa nào có thể xảy ra đối với các tài sản này?

- Những biện pháp nào có thể thực hiện để ứng phó với các đe dọa đó?
-
- **Các khâu của quản lý ATTT:**
 - **Khâu 1:** Xác định rõ mục đích đảm bảo ATTT và lập hồ sơ tổng hợp về các rủi ro.
 - **Khâu 2:** Đánh giá rủi ro đối với từng tài sản ATTT cần bảo vệ.
 - **Khâu 3:** Xác định và triển khai các biện pháp quản lý, kỹ thuật kiểm soát, giảm rủi ro về mức chấp nhận được.
-
- **Tính liên tục của quản lý ATTT:** Quá trình quản lý ATTT cần được thực hiện liên tục do sự thay đổi nhanh chóng của công nghệ (công nghệ mới xuất hiện, hệ thống phức tạp hơn) và môi trường rủi ro liên tục thay đổi (công cụ tấn công, mối đe dọa mới, trình độ tin tặc tăng cao).
- **Chu trình PDCA (Plan-Do-Check-Act):** Được sử dụng để thực hiện quản lý ATTT liên tục.
-
- **Đánh giá rủi ro ATTT:**
 - **Định nghĩa:** Đánh giá rủi ro là một bộ phận quan trọng của quản lý rủi ro, giúp xem xét, nhận dạng và đánh giá mức độ rủi ro của từng tài sản trong tổ chức. Từ đó, xác định mức rủi ro chấp nhận được và đề ra các biện pháp xử lý, kiểm soát rủi ro phù hợp với chi phí.
 - **Các phương pháp tiếp cận đánh giá rủi ro:**
 - **Phương pháp đường cơ sở (Baseline approach):** Thực hiện các kiểm soát an ninh ở mức cơ bản dựa trên tài liệu cơ bản, quy tắc thực hành và các thực tế tốt nhất của ngành.
 - **Ưu điểm:** Không tốn chi phí, có thể triển khai trên nhiều hệ thống.
 - **Nhược điểm:** Không xem xét kỹ các điều kiện khác nhau giữa các tổ chức, mức đường cơ sở chung có thể không phù hợp.
 - **Phù hợp:** Tổ chức có hệ thống CNTT quy mô nhỏ, nguồn lực hạn chế.
 -
 - **Phương pháp không chính thức (Informal approach):** Phân tích rủi ro một cách không chính thức dựa trên kiến thức chuyên gia.
 - **Ưu điểm:** Chi phí thấp, thực hiện nhanh, phân tích hệ thống CNTT giúp đánh giá rủi ro chính xác hơn.
 - **Nhược điểm:** Đánh giá không toàn diện, dễ phụ thuộc vào quan điểm cá nhân.
 - **Phù hợp:** Tổ chức có hệ thống CNTT quy mô nhỏ và vừa, nguồn lực hạn chế.
 -
 - **Phương pháp phân tích chi tiết rủi ro (Detailed risk analysis):** Đánh giá toàn diện, chính thức, chia thành nhiều giai đoạn: nhận dạng tài sản, đe dọa, lỗ hổng, xác suất, hậu quả, lựa chọn biện pháp xử lý.

- **Ưu điểm:** Xem xét chi tiết, giải thích chi phí kiểm soát rủi ro, cung cấp thông tin tốt nhất cho việc quản lý an ninh khi nâng cấp hệ thống.
- **Nhược điểm:** Tốn nhiều thời gian, chi phí, yêu cầu kiến thức chuyên gia cao, có thể làm chậm trễ việc đưa ra biện pháp xử lý.
- **Phù hợp:** Tổ chức chính phủ, tổ chức có hệ thống CNTT quy mô lớn, tổ chức cung cấp hạ tầng truyền thông quốc gia.

■

- **Phương pháp kết hợp (Combined approach):** Kết hợp các thành phần của 3 phương pháp trên.

- **Mục tiêu:** Cung cấp mức bảo vệ hợp lý càng nhanh càng tốt, sau đó kiểm tra và điều chỉnh biện pháp bảo vệ theo thời gian.
- **Các bước:** Thực hiện phương pháp đường cơ sở cho tất cả thành phần, sau đó đánh giá chi tiết các phần quan trọng bằng phương pháp không chính thức, cuối cùng đánh giá toàn diện rủi ro ở mức chi tiết.
- **Ưu điểm:** Dễ nhận được sự ủng hộ của cấp quản lý, triển khai biện pháp xử lý sớm, giảm chi phí.
- **Nhược điểm:** Đánh giá không chính xác trong giai đoạn đầu có thể dẫn đến biện pháp kiểm soát không phù hợp.
- **Phù hợp:** Tổ chức có hệ thống CNTT quy mô vừa và lớn.

■

■

○

2.

3. Giới thiệu bộ chuẩn quản lý ATTT ISO/IEC 27000:

- **Bộ chuẩn ISO 27000:** Là bộ chuẩn về quản lý ATTT được tham chiếu rộng rãi nhất.
- **ISO/IEC 17799:** Tiền thân của ISO 27000, được soạn thảo năm 2000.
- **ISO 17799:2005:** Bản chỉnh sửa của ISO/IEC 17799.
- **ISO 27002:** Tên gọi mới của ISO 17799:2005 (năm 2007), song hành với ISO 27001.
- **ISO/IEC 27002:**
 - Gồm 127 điều, cung cấp cái nhìn tổng quan về nhiều lĩnh vực trong ATTT.
 - Đề ra các khuyến nghị về quản lý ATTT cho người thực hiện.
 - Cung cấp nền tảng cơ sở giúp xây dựng chuẩn ATTT cho tổ chức.
-
- **ISO/IEC 27001:**
 - Cung cấp các thông tin để thực thi các yêu cầu của ISO/IEC 27002 và cài đặt hệ thống quản lý an toàn thông tin (ISMS).
 - Chuyên về hệ thống quản lý an toàn thông tin (ISMS), cung cấp chi tiết cho chu kỳ PDCA.
 - Tập trung vào các phần việc phải thực hiện, không chỉ cách thức thực hiện.
-
- **Chu trình PDCA trong ISO/IEC 27001:**
 - **Plan:** Đề ra phạm vi, chính sách, hướng tiếp cận đánh giá rủi ro, nhận dạng

và đánh giá rủi ro, lựa chọn biện pháp xử lý, mục tiêu kiểm soát, chuẩn bị tuyên bố.

- **Do:** Xây dựng kế hoạch xử lý rủi ro, thực thi các kiểm soát, chương trình đào tạo, quản lý hoạt động và tài nguyên, thủ tục phát hiện và phản ứng sự cố.
- **Check:** Thực thi giám sát, đánh giá hiệu quả ISMS, kiểm toán nội bộ, đánh giá thường xuyên, ghi lại các hành động, sự kiện ảnh hưởng đến ISMS.
- **Act:** Thực hiện cải tiến, hành động sửa chữa, ngăn chặn, áp dụng bài học, thảo luận kết quả, đảm bảo mục tiêu.

○

- **Danh sách các chuẩn con trong ISO/IEC 27000:** Liệt kê các chuẩn con với các chủ đề khác nhau như: Tổng quan, thuật ngữ, quản lý an ninh thông tin, đo lường, quản lý rủi ro, chứng nhận ISMS...

4.

5. Pháp luật và chính sách ATTT:

- **Giới thiệu về pháp luật và chính sách ATTT:**

- **Vai trò:** Chính sách và pháp luật đóng vai trò quan trọng trong việc đảm bảo ATTT, giảm thiểu rủi ro, thiệt hại, và yêu cầu nhân viên ATTT phải hiểu rõ khía cạnh pháp lý và đạo đức.
- **Trách nhiệm nhân viên:** Luôn nắm vững môi trường pháp lý, thực hiện công việc trong khuôn khổ pháp luật, giáo dục ý thức về pháp luật cho nhân viên.
- **Phân biệt Luật và Đạo đức:**
 - **Luật:** Điều khoản bắt buộc hoặc cấm, thường được xây dựng từ văn đề đạo đức, được thực thi bởi cơ quan chính quyền.
 - **Đạo đức:** Định nghĩa hành vi xã hội chấp nhận, dựa trên văn hóa, không được thực thi bởi cơ quan chính quyền.
-
- **Trách nhiệm của tổ chức:** Mở rộng ra ngoài phạm vi luật hình sự và hợp đồng, bao gồm trách nhiệm pháp lý phải hoàn trả và đền bù sai trái. Tổ chức phải chịu trách nhiệm cho hành vi của nhân viên.
- **Chính sách và Luật:**
 - **Chính sách (nội quy):** Quy định về hành vi chấp nhận được của nhân viên trong tổ chức, có giá trị thực thi trong nội bộ, cần được nghiên cứu, soạn thảo kỹ lưỡng, cần đầy đủ, đúng đắn, áp dụng công bằng.
 - **Khác biệt:** Luật luôn bắt buộc, còn thiếu hiểu biết chính sách không phải là một cách bào chữa được chấp nhận.
-
- **Yêu cầu của chính sách:** Phổ biến (Dissemination), Xem xét (Review), Có thể hiểu (Comprehension), Tuân thủ (Obligation), Áp dụng đồng đều (Uniform enforcement).
- **Các kiểu luật:** Luật dân sự, hình sự, công cộng, riêng.

○

- **Luật quốc tế về ATTT:**

- **Luật ATTT của Mỹ:**

- Luật tội phạm máy tính (Computer Fraud and Abuse Act, Computer

Security Act, National Information Infrastructure Protection Act, USA PATRIOT Act, USA PATRIOT Improve-ment and Reauthorization Act).

- Luật về sự riêng tư (Federal Privacy Act, Electronic Communications Privacy Act, Health Insurance Portability and Accountability Act, Financial Services Modernization Act).
- Luật xuất khẩu và chống gián điệp (Economic Espionage Act, Security and Freedom through Encryption Act).
- Luật bản quyền (U.S. Copyright Law).
- Luật tự do thông tin (Freedom of Information Act).

- **Luật ATTT và tổ chức luật quốc tế:** Hội đồng châu Âu về chống tội phạm mạng, Hiệp ước bảo vệ quyền sở hữu trí tuệ, Digital Millennium Copyright Act.

○

○ **Luật Việt Nam về ATTT:**

- **Luật ATTT mạng:** (86/2015/QH13), có hiệu lực từ 1/7/2016, bao gồm 8 chương, 54 điều.
- **Luật An ninh mạng:** Có hiệu lực từ 1/1/2019.
- **Các văn bản khác liên quan:** Luật CNTT, Nghị định về chống thư rác, Quyết định về chữ ký số, Quy hoạch phát triển an toàn thông tin số quốc gia, Thông tư về quản lý thông tin trên mạng truyền số liệu, Nghị định sửa đổi nghị định về chống thư rác, Nghị định về quản lý dịch vụ internet và thông tin trên mạng.

○

6.

7. **Vấn đề đạo đức ATTT:**

- **Quy tắc ứng xử:** Các tổ chức xã hội nghề nghiệp đã ban hành quy tắc ứng xử, ví dụ như luật sư, bác sĩ có thể bị cấm hành nghề nếu vi phạm, vận động viên thể thao bị cấm thi đấu.
- **Quy tắc ứng xử trong CNTT/ATTT:** Các tổ chức ACM và ISSA hợp tác xây dựng quy tắc ứng xử, nhưng chỉ mang tính khuyến nghị. Hiệp hội ATTT Việt Nam cũng công bố bộ quy tắc ứng xử ATTT.
- **Bộ Quy tắc ứng xử 10 điểm của Viện đạo đức máy tính:** Đề xuất 10 nguyên tắc đạo đức cơ bản khi sử dụng máy tính.
- **Sự khác biệt về đạo đức giữa các nền văn hóa:** Nhận thức về đạo đức khác biệt giữa các quốc gia, hành vi được phép ở quốc gia này có thể vi phạm đạo đức ở quốc gia khác. Ví dụ, tỷ lệ vi phạm bản quyền phần mềm ở các nước phát triển thường thấp hơn so với các nước đang phát triển.
- **Vấn đề vi phạm bản quyền phần mềm:** Nghiêm trọng ở các nước đang phát triển, người dùng coi việc dùng phần mềm bất hợp pháp là bình thường do quy định hoặc xử lý chưa nghiêm.
- **Vấn đề lạm dụng tài nguyên công ty, tổ chức:** Nhiều công ty chưa có quy định hoặc thực thi chưa chặt chẽ về việc sử dụng tài nguyên công ty vào mục đích cá nhân.

8.

Tổng kết:

Chương này cung cấp một cái nhìn tổng quan về quản lý ATTT, các phương pháp đánh giá rủi ro, bộ chuẩn ISO/IEC 27000, pháp luật và chính sách ATTT (cả quốc tế và Việt Nam), và những vấn đề đạo đức liên quan đến ATTT. Những nội dung này là nền tảng quan trọng để đảm bảo an ninh và bảo mật hệ thống thông tin một cách hiệu quả.